

L2 - 1.4. Defensive Security Trends

Task 1 - Introduction

This room will help you prepare for both duties by exploring many interesting cyber trends.

Task 2 - Attacks Become Faster

- The DFIR Report shared a case where ransomware was deployed in under 4 hours ([Report\(opens in new tab\)](#))
- Malwarebytes shared a ransomware case happening within 8 hours ([Blog post\(opens in new tab\)](#))
- Huntress reports the average time-to-ransomware was almost 17 hours ([Report\(opens in new tab\)](#))
- CrowdStrike reports the fastest recorded eCrime breakout time was 27 seconds ([Report\(opens in new tab\)](#)) **Note:** Breakout time means a pause between the initial access and attack impact

How SOCs Can Prepare

#	Recommendation	Description
1	Contain first, investigate second	Use EDR capabilities and SOAR playbooks to contain the threats before a human analyst joins, and then use your log analysis skills to dig deeper, finalize the response, and tune the tools if needed.
2	Address detected security gaps	Always report detected vulnerabilities and misconfigurations to your IT team and control the fixes. The better your network is configured, the longer attacks will take, and the more time you'll have to stop them.

#	Recommendation	Description
3	Automate time-consuming routine	Think about which part of your triage takes the most time and optimize or automate it. It may be a slow SIEM, a lack of context, or just a ticketing routine. Your goal is to begin a response as soon as possible.

Answer the questions below

Refer to the mentioned Huntress report. What is the reported average time-to-ransomware?

17 hours

What should SOC's do with triage routine to speed up response?

Automate it

Task 3 - Attacks Become Complex

- DarkGate malware was [delivered\(opens in new tab\)](#) via AnyDesk, a commonly used remote access tool
- Shai-Hulud worm [used\(opens in new tab\)](#) a legitimate scanner, Trufflehog, to harvest the victim's secrets
- APT41 [implemented\(opens in new tab\)](#) its Command & Control channel via the Google Calendar API
- Cybercrime services like [Fox Tempest\(opens in new tab\)](#) can digitally sign malware binaries for a price

Overall, once adversaries see a new trend in defensive security (such as AI-assisted triage) that is too effective against regular attacks, they quickly come up with clever bypasses. A few examples:

- Since EDR solutions are getting more popular, [EDR killers\(opens in new tab\)](#) are developing as well
- Instead of regular attacks, adversaries [recruit\(opens in new tab\)](#) insiders who would sell admin access

- Attackers can even use trusted defensive tools against defenders themselves (E.g., attackers [installed](#) Velociraptor, a legitimate DFIR tool, to control the victims)

Answer the questions below

Which of the mentioned remote access tools was used by DarkGate malware?

AnyDesk

Is the network perimeter becoming more predictable in modern environments?
(Yea/Nay)

Nay

Task 4 - Attacks via Valid Accounts

Valid Accounts: *Valid accounts abuse was observed in 39% of recorded incidents (Verizon 2026 Data Breach Investigations Report([opens in new tab](#)))*

Data Stealers: Even if the company enforces MFA, infostealers can steal browser sessions, access tokens, SSH keys, and other authentication materials that work without MFA. *Two real-world examples of how AMOS infostealer appears on the workstations (PCrиск([opens in new tab](#)), CloudSEK([opens in new tab](#)))*

Darknet Markets: The buyers of the logs are typically Initial Access Brokers (IAB), groups dedicated to filtering the "logs" and reselling the valid credentials to ransomware groups. *One of the darknet markets selling the "logs" from Lumma stealer (SOCRadar([opens in new tab](#)))*

SOC Tips: Attackers can get valid credentials from many sources, but the tips are the same:

- Allow logins only from corporate devices (e.g., with [Entra ID Conditional Access](#)([opens in new tab](#)))
- Develop rules that look for anomalous logins (e.g., logins from [known VPN addresses](#)([opens in new tab](#)))
- When in doubt, better disable the user and contact the employee to approve the login

Answer the questions below

Refer to the screenshot of the Verizon 2026 report. What percentage of incidents contained Valid accounts?

39%

How do you call cyber criminals who sell access to organizations' networks?

Initial Access Brokers

Task 5 - Supply Chain Attacks

What Is a Supply Chain Attack: *A supply chain attack is a cyberattack where an attacker compromises a trusted third-party vendor, software, library, or service that an organization relies on, instead of directly attacking the organization. The attacker then uses that trusted relationship to distribute malware, steal data, or gain unauthorized access.*
Statistics of Software Supply Chain Attacks
([Sonatype](#)(opens in new tab))

Vercel 2026 Incident: Supply chain attacks are hard to detect and respond to. Suddenly, a trusted program would start doing malicious actions, and you won't know why until someone else reports it on GitHub, Twitter, or Reddit. Even worse is when your cloud provider is breached, such as during the Vercel April 2026 incident. The adversaries:

1. Compromised Context.ai by using AWS cloud credentials, stolen with Lumma Stealer
2. Exfiltrated OAuth tokens of Context.ai customers, including Vercel (Context.ai → Vercel chain)
3. Used the Vercel OAuth token to move laterally to internal Vercel systems and databases
4. Exfiltrated secrets of Vercel customers, affecting many companies (Vercel → Customers chain)

Vercel April 2026 supply chain diagram ([Trend Micro](#)(opens in new tab))

Tips for SOC Teams

Supply Chain Incident	Detection Tips	Response Tips
Vercel, 2026 (opens in new tab). (PaaS for web apps)	Monitor for supply chain threats in cyber news and hunt for traces of infection in your organization once the details are public.	Ensure the least privilege principle. Even if the attackers get the keys, they shouldn't be able to open every door in your network.
Axios, 2026 (opens in new tab). (JavaScript library)	Never discard the alerts just because the process chain starts from a trusted application. First, check for indicators of a supply chain attack.	Wait 3+ days before updating dependencies. Most malicious packages are revoked within hours once the community catches them.
DAEMON Tools, 2026 (opens in new tab). (Imaging Software)	No matter if the threat comes from a browser or DAEMON Tools, the next attack steps are usually the same. Ensure your SOC has a good MITRE coverage.	Install EDR and implement application control that blocks software not needed for work.

Answer the questions below

Refer to the explained Vercel supply chain incident. What malware was the first link in the attack chain?

Lumma Stealer

Imagine a supply chain attack hits your organization. Would attack TTPs fundamentally differ from other intrusions? (Yea/Nay)

Nay

Task 6 - AI Impact on Cyber Security

AI for SOC Analysts: AI automates SOC tasks such as alert triage, enrichment, deobfuscation, and report writing. *Example of SIEM and Claude integration* ([Panther](#)(opens in new tab).)

Be Careful With the AI Boom!

- Juniors will over-rely on AI verdicts without a proper mentorship

- IT will spin up new infrastructure faster than SOC can onboard it
- Other departments will start using random, insecure AI plugins
- Try to keep things under SOC control and hold people accountable

AI for Adversaries: Attackers use AI to automate phishing, malware creation, vulnerability discovery, and other offensive activities. *"Fail" means an employee opened a phishing email, created by a human red teamer or AI (Hoxhunt(opens in new tab))*

AI-Themed Attacks: AI introduces new attack surfaces and enables AI-themed phishing and malicious software, requiring stronger security awareness.

Answer the questions below

| Should AI become a final decision maker in a SOC? (Yea/Nay)

Nay

| Which MITRE technique became obsolete due to AI?

None

Task 7 - Research Challenge

1. GitHub 2026 Breach

On May 18, adversaries accessed ~3,800 internal repositories of GitHub.

The attack was made possible thanks to a multi-layer supply chain attack.

Start from the official announcement and OSINT the details to answer the questions:

<https://github.blog/security/investigating-unauthorized-access-to-githubs-internal-repositories/>(opens in new tab).

2. Verizon DBIR Report

The latest Verizon DBIR report is packed with valuable insights.

To answer the questions, focus on the sections confirming that:

- Adversaries are using adminware and RMM tools (AnyDesk, ScreenConnect) more than ever
- Valid accounts harvested by infostealers and sold by IABs are then used in ransomware attacks

<https://www.verizon.com/business/resources/T1ae/reports/2026-dbir-data-breach-investigations-report.pdf>(opens in new tab).

Answer the questions below

The GitHub breach started from an infection of an employee's device. Which VS Code extension was backdoored with an infostealer?

Nx Console

The extension was compromised through another supply chain attack. Which open-source package ecosystem was the root cause?

TanStack

Open the Verizon report to page 40 (System Intrusion section). How much has threat actor RMM usage grown year-over-year? (e.g., 50%)

240%

Continue to the Infostealer to ransomware pipeline section a few pages later. Which access type do Initial Access Brokers most commonly sell? (e.g. SSH)

VPN